

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A
MOCK INTERVIEW

Code of Conduct:

I S. Harsha Vardhan Reddy (192325029) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

S. Harsha Vardhan Reddy

Annexure A

MOCK INTERVIEW

1. Which would you prioritize in a secure network design: **performance or security**, and how would you balance both?
2. Can you explain the difference between **stateful and stateless firewalls**, and which one is more suitable for enterprise networks?
3. If an IDS generates too many false positives, how would you optimize its performance?
4. How would you design a **real-time intrusion detection system** for high-speed networks?
5. What are the key challenges in detecting **zero-day malware**, and how would you address them?
6. How would you differentiate between **signature-based and anomaly-based IDS**, and when would you use each?
7. If a network is under a **DDoS attack**, what immediate and long-term mitigation strategies would you apply?
8. How would you secure **remote access** to an enterprise network?
9. What are the limitations of **traditional antivirus software**, and how can modern solutions overcome them?
10. How would you design a **secure email filtering system** to prevent phishing and spam attacks?
11. If an attacker bypasses firewall rules, what additional layers of security would you implement?
12. How would you evaluate the effectiveness of **network segmentation** in preventing cyberattacks?
13. What role does **encryption** play in preventing malware attacks, if any?
14. How would you secure a **cloud-based network infrastructure**?
15. What is the importance of **log analysis and monitoring** in network security?
16. How would you respond to a **security breach in a corporate network**?
17. What are the advantages and limitations of **next-generation firewalls (NGFW)**?
18. How would you integrate **IDS/IPS with SIEM systems** for better threat detection?
19. What are the best practices for **patch management and vulnerability assessment**?
20. How would you design a **future-proof network security architecture** considering emerging threats?

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive attitude, and	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism

		professional behavior throughout			
--	--	--	--	--	--

MOCK INTERVIEW — NETWORK SECURITY

1. Which would you prioritize in a secure network design: performance or security, and how would you balance both?

Answer:

I would not treat performance and security as competing goals. I would first establish the required security level and then optimize the architecture so that security controls introduce minimum overhead.

For example, I would use optimized firewall rules, traffic filtering, load balancing, caching, and selective deep inspection. High-risk traffic can receive deeper inspection while trusted or low-risk traffic is processed more efficiently.

In an interview:

“Security is the priority, but it must be designed for performance. I would use layered security, optimized rules, selective inspection, and monitoring to achieve both.”

2. Can you explain the difference between stateful and stateless firewalls, and which one is more suitable for enterprise networks?

Answer:

A **stateless firewall** examines each packet independently using predefined rules such as source IP, destination IP, port, and protocol.

A **stateful firewall** maintains a connection table and understands whether a packet belongs to an established session.

For enterprise networks, I would generally prefer a **stateful firewall** because it provides better context-aware filtering and can automatically allow valid response traffic while rejecting unsolicited packets.

The trade-off is that stateful firewalls require additional memory and processing to maintain connection information.

3. If an IDS generates too many false positives, how would you optimize its performance?

Answer:

I would first analyze the alerts to identify the major sources of false positives.

My approach would be:

1. Tune detection thresholds.
2. Remove obsolete or duplicate signatures.
3. Whitelist trusted systems where appropriate.
4. Use environment-specific rules.
5. Improve anomaly-detection baselines.
6. Correlate multiple events before generating high-priority alerts.
7. Continuously measure precision, recall, and false-positive rate.

I would avoid simply disabling large numbers of signatures because that could create security gaps.

4. How would you design a real-time intrusion detection system for high-speed networks?

Answer:

For a high-speed network, I would use a **multi-stage detection architecture**.

Network Traffic



High-Speed Packet Capture



Traffic Filtering



Signature Detection



Flow/Behavior Analysis



ML/Anomaly Detection



Alert + Response



SIEM

I would use flow-level analysis and lightweight signatures for normal traffic, while sending only suspicious traffic for deeper inspection. Parallel processing, efficient data structures, sampling where appropriate, and distributed sensors would help maintain low latency.

5. What are the key challenges in detecting zero-day malware, and how would you address them?**Answer:**

The biggest challenge is that zero-day malware has no previously known signature. Traditional signature-based antivirus may therefore fail to detect it.

I would use multiple techniques:

- Behavioral analysis.
- Sandboxing.
- Endpoint detection and response.
- Anomaly detection.
- Machine-learning models.
- Application control.
- Network behavior monitoring.

For example, even if a malware sample has an unknown hash, suspicious behavior such as unauthorized persistence, privilege escalation, process injection, or mass file modification can trigger detection.

6. How would you differentiate between signature-based and anomaly-based IDS, and when would you use each?**Answer:**

Signature-Based IDS

Detects known attack patterns

Fast

Usually lower false positives

Poor against new attacks

Easy to understand

Anomaly-Based IDS

Detects deviations from normal behavior

Can require more processing

Potentially higher false positives

Better for unknown attacks

Requires baseline/training

I would use **signature-based detection** for known threats and **anomaly detection** for unknown or evolving threats.

In an enterprise, I would normally combine both in a **hybrid IDS**.

7. If a network is under a DDoS attack, what immediate and long-term mitigation strategies would you apply?

Answer:

Immediate actions:

- Identify the attack type.
- Enable rate limiting.
- Block clearly malicious sources where practical.
- Use firewall/IPS controls.
- Apply traffic filtering.
- Redirect traffic to DDoS protection infrastructure.
- Protect critical services first.

Long-term measures:

- Deploy scalable DDoS protection.
- Use CDN/anycast architecture where appropriate.
- Improve network redundancy.
- Establish traffic baselines.
- Create automated response procedures.
- Regularly test the incident-response plan.

The key is to mitigate the attack without unnecessarily taking the entire service offline.

8. How would you secure remote access to an enterprise network?

Answer:

I would use a **Zero Trust-oriented remote-access architecture** rather than trusting a user simply because they connected through a VPN.

Important controls include:

- Multi-factor authentication.
- Strong encryption.
- Device-health verification.
- Least-privilege access.
- Role-based authorization.
- Network segmentation.
- Continuous monitoring.

- Session timeout.
- Endpoint security.

For sensitive resources, I would use application-level access rather than giving the remote user broad network access.

9. What are the limitations of traditional antivirus software, and how can modern solutions overcome them?

Answer:

Traditional antivirus primarily relies on known signatures, so it can struggle with:

- Zero-day malware.
- Polymorphic malware.
- Fileless attacks.
- Living-off-the-land techniques.
- Rapidly modified malware.

Modern solutions combine signature detection with:

- Behavioral analysis.
- Machine learning.
- Endpoint Detection and Response (EDR).
- Cloud threat intelligence.
- Sandboxing.
- Application control.

This provides both known-threat and behavioral detection.

10. How would you design a secure email filtering system to prevent phishing and spam attacks?

Answer:

I would use multiple filtering layers:

Incoming Email



Sender Reputation



SPF/DKIM/DMARC Validation



Spam Detection



Malware Scanning



URL Analysis



Attachment/Sandbox Analysis



Content & Behavioral Analysis



Inbox / Quarantine / Reject

I would also use phishing-aware URL analysis and attachment sandboxing. Security awareness training is another important layer because technical controls cannot eliminate every social-engineering attack.

11. If an attacker bypasses firewall rules, what additional layers of security would you implement?

Answer:

I would follow **defense in depth**.

Additional controls would include:

- IDS/IPS.
- Network segmentation.
- Endpoint Detection and Response.
- Identity and access management.
- MFA.
- Application security.
- Data-loss prevention.
- SIEM monitoring.
- Vulnerability management.
- Encryption.
- Incident-response controls.

The firewall should be only one security layer, not the organization's entire security boundary.

12. How would you evaluate the effectiveness of network segmentation in preventing cyberattacks?

Answer:

I would evaluate whether segmentation limits lateral movement after an initial compromise.

Important metrics include:

- Number of reachable systems from a compromised host.
- Number of blocked unauthorized connections.
- Reduction in lateral movement paths.
- Mean time to detect and contain incidents.
- Attack-path reduction.
- Firewall/ACL violations.
- Results of penetration tests and attack simulations.

If compromising one endpoint no longer provides easy access to critical servers, the segmentation is working effectively.

13. What role does encryption play in preventing malware attacks, if any?

Answer:

Encryption does not directly prevent malware from executing. Its primary purpose is to protect **confidentiality and integrity**.

For example:

- TLS protects data in transit.
- Disk encryption protects stored data.
- Secure protocols protect credentials and sensitive information.

However, encryption can also complicate security monitoring because attackers may hide malicious traffic inside encrypted connections. Therefore, organizations need appropriate endpoint and network-security controls to detect threats without unnecessarily weakening confidentiality.

14. How would you secure a cloud-based network infrastructure?

Answer:

I would use a layered cloud-security architecture.

Key controls include:

- Strong IAM and least privilege.
- MFA.
- Network segmentation using cloud security groups and network policies.
- Encryption at rest and in transit.
- Secrets management.
- Continuous logging and monitoring.
- Vulnerability scanning.
- Secure configuration management.
- Web application firewalls.
- Backup and disaster recovery.
- Infrastructure-as-code security checks.

I would also continuously monitor cloud configurations because cloud environments change frequently.

15. What is the importance of log analysis and monitoring in network security?

Answer:

Logs provide evidence of what happened before, during, and after a security incident.

They help security teams:

- Detect suspicious behavior.
- Investigate attacks.
- Correlate events.
- Identify compromised accounts.
- Perform forensic analysis.
- Meet compliance requirements.
- Improve incident response.

I would centralize important logs in a **SIEM** and configure meaningful alerts rather than generating alerts for every event.

16. How would you respond to a security breach in a corporate network?

Answer:

I would follow a structured incident-response process:

Identification

↓
Containment

↓
Eradication

↓
Recovery

↓
Lessons Learned

First, I would confirm the incident and determine its scope. Then I would isolate affected systems to prevent further spread.

After that, I would remove the root cause, patch vulnerabilities, reset compromised credentials, restore systems safely, and continuously monitor for reinfection.

Finally, I would document the incident and improve controls based on lessons learned.

17. What are the advantages and limitations of next-generation firewalls (NGFW)?

Answer:

Advantages:

- Application-aware filtering.
- User/identity-based policies.
- Integrated intrusion prevention.
- URL filtering.
- Malware detection.
- Better visibility.
- Advanced traffic inspection.

Limitations:

- Higher processing overhead.
- More complex configuration.
- Greater cost.
- Encryption can reduce inspection visibility.
- Poorly configured rules can still create security gaps.

An NGFW is powerful, but it should still be part of a broader defense-in-depth architecture.

18. How would you integrate IDS/IPS with SIEM systems for better threat detection?

Answer:

I would send IDS/IPS alerts and relevant network events to the SIEM.

Network

↓
IDS/IPS

↓
Security Events

↓
SIEM

↓
Correlation + Risk Analysis

↓
Alert

↓
SOC Response

The SIEM can correlate an IDS alert with authentication logs, endpoint events, firewall logs, and cloud activity.

For example, an unusual login followed by suspicious network traffic and endpoint activity would have a higher priority than any individual event.

This reduces isolated alerts and provides better incident context.

19. What are the best practices for patch management and vulnerability assessment?

Answer:

I would follow a continuous vulnerability-management cycle:

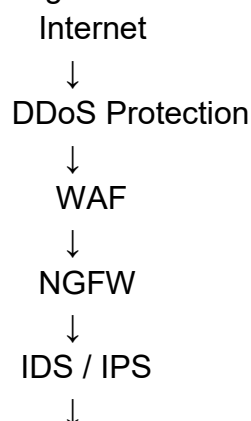
1. Maintain an accurate asset inventory.
2. Scan systems regularly.
3. Identify vulnerabilities.
4. Assign risk based on severity and business impact.
5. Prioritize critical vulnerabilities.
6. Test patches.
7. Deploy patches in controlled stages.
8. Verify successful installation.
9. Monitor for problems.
10. Document exceptions.

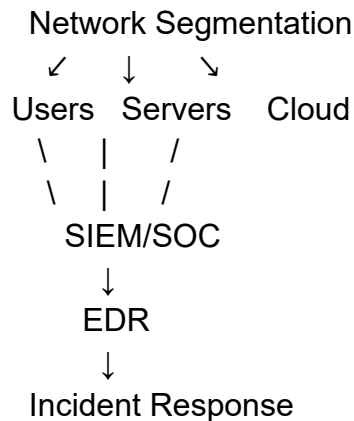
I would prioritize vulnerabilities that are **actively exploited, internet-facing, or affecting critical systems** rather than patching purely according to vulnerability count.

20. How would you design a future-proof network security architecture considering emerging threats?

Answer:

I would design a **Zero Trust and defense-in-depth architecture** that can evolve as threats change.





The architecture should include:

- Zero Trust access.
- MFA and strong identity management.
- Network segmentation.
- EDR/XDR.
- AI/ML-assisted detection where appropriate.
- Continuous monitoring.
- Automated incident response.
- Encryption.
- Secure cloud architecture.
- Regular vulnerability assessment.
- Strong backup and recovery.
- Security awareness training.

Strong interview closing answer

“My approach to network security is defense in depth. I would never depend on a single firewall, IDS, or antivirus solution. I would combine identity security, segmentation, encryption, endpoint protection, network monitoring, SIEM-based correlation, vulnerability management, and incident response. At the same time, I would continuously measure detection accuracy, false positives, latency, and system performance so that security controls remain effective without unnecessarily affecting business operations.”